보안취약점관리기준

문서번호: HB-SEC-103
보안등급: 비밀
시행일: 2025-11-20
개정차수: 1

제1조(목적)

이 기준은 한빛시장정보(주)(이하 "회사"라 한다)의 정보 시스템과 응용 프로그램에 존재하는 보안 취약점을 체계적으로 발견, 평가, 조치하여 침해사고의 가능성을 낮추는 데 필요한 사항을 정함을 목적으로 한다.

이 기준은 회사가 운영하거나 개발하는 모든 정보 시스템에 적용한다.

이 기준은 외부 위탁 업체가 운영하는 시스템 중 회사의 데이터를 처리하는 부분에도 적용하며, 위탁 계약에 이 기준의 준수 의무를 포함한다.

제2조(정의)

이 기준에서 사용하는 용어의 뜻은 다음과 같다.

1. "보안 취약점"이란 공격자가 악용하여 시스템의 기밀성, 무결성, 가용성을 해칠 수 있는 약점을 말한다.
2. "취약점 점검"이란 도구나 수작업으로 취약점을 찾아내는 활동을 말한다.
3. "모의해킹"이란 실제 공격 기법을 사용하여 시스템의 취약 여부를 확인하는 점검을 말한다.
4. "보안 패치"란 취약점을 제거하기 위해 제공되는 수정 프로그램을 말한다.
5. "예외 승인"이란 정해진 조치 기한 안에 조치하기 어려운 취약점에 대하여 사유를 인정하고 기한을 연장하는 승인을 말한다.

제3조(점검 대상)

취약점 점검의 대상은 다음과 같다.

1. 시세 전송 시스템과 종목 마스터 배포 시스템을 포함한 운영 서버
2. 네트워크 장비와 보안 장비
3. 참가사에 제공하는 외부 접속 응용 프로그램과 API
4. 새로 도입하거나 크게 변경하는 시스템

점검 대상 목록은 정보보호팀이 관리하며 분기마다 갱신한다.

점검 대상에서 제외하려는 시스템이 있는 경우 담당 부서장은 사유를 적어 정보보호팀의 확인을 받아야 한다.

외부 업체가 관리하는 시스템은 위탁 계약에 따라 업체가 점검 결과를 회사에 제출하도록 한다.

제4조(취약점 등급)

발견된 취약점은 공격 가능성과 피해 규모를 고려하여 긴급, 고위험, 중위험, 저위험의 네 등급으로 구분한다.

등급 판정은 정보보호팀이 하며, 판정이 어려운 경우 정보보호최고책임자가 최종 결정한다.

외부에 공개된 공격 코드가 있거나 실제 공격이 확인된 취약점은 한 단계 높은 등급으로 판정한다.

등급 판정 결과는 취약점을 통보할 때 함께 담당 부서에 알리며, 담당 부서가 등급에 이의가 있으면 통보를 받은 후 3영업일 안에 근거를 적어 정보보호팀에 재검토를 요청할 수 있다.

저위험 취약점은 시스템에 미치는 영향이 제한적인 약점을 말한다.

제5조(조치 기한)

취약점은 판정된 등급에 따라 다음의 기한 안에 조치하여야 한다.

1. 긴급 취약점: 7일
2. 고위험 취약점: 30일
3. 중위험 취약점: 90일

기한은 정보보호팀이 취약점을 담당 부서에 통보한 날부터 계산한다.
저위험 취약점은 정기 점검 주기 안에 조치하는 것을 원칙으로 한다.
조치 기한 안에 조치가 끝나지 않을 것으로 예상되는 경우 담당 부서는 기한이 지나기 전에 정보보호팀에 알려야 한다.
긴급 취약점은 조치가 끝날 때까지 정보보호팀이 매일 진행 상황을 확인하고, 필요한 경우 임시 차단 조치를 먼저 시행하게 할 수 있다.

제6조(조치 확인)
담당 부서는 조치를 마친 후 조치 내용을 정보보호팀에 알려야 하며, 정보보호팀은 5영업일 이내에 재점검하여 조치가 올바르게 이루어졌는지 확인한다.
재점검 결과 취약점이 제거되지 않았으면 담당 부서에 다시 조치를 요구하고, 기한은 처음 통보일부터 계속 계산한다.
재점검은 처음 취약점을 발견한 방법과 같은 방법으로 하는 것을 원칙으로 하며, 필요하면 다른 방법을 추가한다.
재점검 결과는 취약점 관리 대장에 기록하고 담당 부서에 알린다.

제7조(예외 승인)
기술적 제약이나 서비스 영향 때문에 정해진 기한 안에 조치할 수 없는 경우 담당 부서장은 사유와 보완 대책을 적어 예외 승인을 신청할 수 있다.
예외 승인은 정보보호최고책임자가 하며, 승인 기간은 한 번에 최대 60일로 한다.
예외 승인을 받은 취약점은 보완 대책이 유지되는지 월 1회 확인한다.
예외 승인 신청서에는 취약점의 내용, 조치가 어려운 사유, 보완 대책, 조치 완료 예정일을 포함하여야 한다.
승인 기간이 끝났는데도 조치가 되지 않은 경우에는 다시 예외 승인을 받아야 하며, 연속하여 두 번을 넘어서는 승인할 수 없다.

제8조(보안 패치 적용)
운영 서버에 보안 패치를 적용하기 전에 개발 환경 또는 시험 환경에서 서비스에 미치는 영향을 확인하여야 한다.
패치는 시세 전송이 없는 시간대에 적용하는 것을 원칙으로 하며, 적용 후 서비스 상태를 점검한다.
패치 적용이 어려운 경우에는 접근 통제 강화 등 임시 방안을 병행한다.
패치 적용 전에는 적용 대상 시스템의 백업을 완료하고, 문제가 생기면 이전 상태로 되돌릴 수 있는 방법을 준비한다.
패치의 적용 결과는 취약점 관리 대장에 기록한다.

제9조(점검 주기)
취약점 점검은 다음의 주기에 따라 실시한다.
1. 자동화 도구를 이용한 점검은 월 1회 실시한다.
2. 외부 모의해킹은 연 1회 실시한다.
3. 신규 시스템은 운영을 시작하기 전에 점검한다.
외부 모의해킹은 회사와 이해관계가 없는 전문 기관에 의뢰하며, 점검 범위와 방법은 사전에 정보보호최고책임자의 승인을 받는다.
자동화 도구를 이용한 점검에서 발견된 오탐은 정보보호팀이 확인하여 점검 결과에서 제외하고, 제외 사유를 기록한다.
모의해킹 중 서비스에 장애가 생길 우려가 있는 경우에는 점검을 즉시 중단하고 정보보호팀에 알려야 한다.

제10조(점검 결과의 관리)
점검 결과는 취약점의 내용, 등급, 담당 부서, 조치 기한과 조치 현황을 담은 취약점 관리 대장에 기록한다.

취약점 관리 대장은 정보보호팀이 관리하며 접근할 수 있는 사람을 제한한다.
점검 결과 보고서는 작성일부터 3년간 보관한다.
취약점 관리 대장과 점검 결과 보고서는 비밀 등급으로 관리하며, 열람하려는 사람은 정보보호팀장의 사전 승인을 받아야 한다.

제11조(보고)
정보보호팀은 분기마다 취약점 조치 현황을 정보보호최고책임자에게 보고한다.
조치 기한을 넘긴 취약점이 있는 경우에는 그 사유와 향후 계획을 함께 보고하며, 기한을 넘긴 상태가 계속되면 대표이사에게도 보고한다.
정보보호팀은 새로 알려진 중대한 취약점이 회사의 시스템에 영향을 줄 수 있다고 판단하면 정기 보고를 기다리지 않고 즉시 정보보호최고책임자에게 알린다.

부칙
이 기준은 2025-11-20부터 시행한다.